

-

File No.: EXP202101323

RESOLUTION OF SANCTIONING PROCEDURE

From the procedure initiated by the Spanish Agency for Data Protection and based on the following

BACKGROUND

FIRST:

A.A.A. on July 12, 2021, and B.B.B. on October 14, 2021, (hereinafter, the claimants) filed respective complaints with the Spanish Agency for Data Protection. Both complaints are directed against AYUNTAMIENTO DE RIOTORTO with NIF P2705400F (hereinafter, the respondent or the City Council).

The reasons on which these complaints are based are as follows:

The claimants, along with other XXXXX neighbors, submitted a letter to the AYUNTAMIENTO DE RIOTORTO on March 26, 2021, communicating the existence of a series of incidents related to the payment for the potable water supply service.

Subsequently, the City Council sent a communication to each of the neighbors in the locality announcing the upcoming visit of inspection services to verify the correctness of the installations and, if necessary, rectify the observed irregularities. Along with this communication, a copy of the letter submitted on March 26, 2021, was sent, including the identifying personal data of all signatories. The claimants stated that the inclusion of their personal data in the disputed document was unnecessary and unjustified.

SECOND: In accordance with Article 65.4 of Organic Law 3/2018, of December 5, on Personal Data Protection and Guarantee of Digital Rights (hereinafter LOPDGDD), the complaint was forwarded to the respondent, so that it could analyze it and inform this Agency within one month of the actions taken to comply with the requirements set forth in data protection regulations.

The transfer, which was carried out in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), was acknowledged on August 20, 2021, as evidenced by the acknowledgment of receipt in the file.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

On September 21, 2021, a response was received by this Agency. In summary, it indicated the following:

The City Council sent a communication to the neighbors of the municipality warning of the upcoming inspection visit, for the purpose of reviewing the water meters. Along with this communication, a copy of the complaint submitted by XXXXX neighbors was sent, which only included the handwritten names and surnames of the claimants.

The City Council limited itself to informing the interested parties in the administrative procedure initiated as a result of the complaint of the reason for the initiation and the inspection action that the City Council was going to carry out, accompanying the complaint so that they were aware of the exact terms of it, information to which they were entitled as interested parties in that procedure. Article 53.1 a) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), the second legal basis of the Judgment of the Superior Court of Justice of Catalonia No. 5322/2020, of December 21, and Article 48 of Law 29/1998 were mentioned.

The City Council considered that it had not committed any type of irregularity. It also indicated that, in the event that it was found that the municipal action was irregular, appropriate measures would be taken to prevent a situation like the one that was the subject of the complaint from occurring again in the future.

THIRD: On October 29, 2021, after analyzing the documentation in the file, a resolution was issued by the Director of the Spanish Agency for Data Protection, agreeing to archive the complaint. The

resolution was notified to the party B.B.B. on December 16, 2021.

FOURTH: On January 17, 2022, B.B.B. filed a request for reconsideration through the Electronic Registry of the AEPD, against the resolution issued in file ***EXPEDIENTE.1, in which he expressed his disagreement with the contested resolution, highlighting that the City Council had not taken any measures to prevent the unauthorized transfer of personal data. He added that the argument that the inclusion of personal data was required by the regulations governing the administrative procedure was incorrect, as the provisions regarding access to the administrative file, which had not been requested by any of the parties, were not applicable to the sending of administrative notifications such as the one made.

FIFTH: On July 27, 2022, the appeal filed was sent to the respondent in accordance with the provisions of Article 118.1 of the LPACAP for the purpose of formulating allegations and presenting the documents and evidence deemed appropriate, which was verified by the respondent through a response letter dated August 5, 2022.

SIXTH: On October 21, 2022, a Resolution was issued in which the request for reconsideration filed by B.B.B. against the Resolution of the AEPD of October 29, 2021, which agreed to archive the complaint referred to the

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

3/12

MUNICIPALITY OF RIOTORTO. The Resolution was notified to B.B.B. on November 2, 2022.

SEVENTH: On January 5, 2023, the Director of the Spanish Agency for Data Protection agreed to initiate sanctioning proceedings against the respondent, for the alleged infringement of Article 5.1.f) of the GDPR, classified under Article 83.5 of the GDPR, and for the alleged infringement of Article 32 of the GDPR, classified under Article 83.4 of the GDPR.

EIGHTH: The aforementioned initiation agreement was notified in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP) and after the period granted for the submission of allegations had elapsed, it has been confirmed that no allegations have been received from the respondent.

Article 64.2.f) of the LPACAP - a provision of which the respondent was informed in the opening agreement of the procedure - establishes that if no allegations are made within the stipulated period regarding the content of the initiation agreement, when it contains a precise statement regarding the responsibility attributed, it may be considered a proposal for resolution. In this case, the initiation agreement of the sanctioning file determined the facts on which the accusation was based, the infringement of the GDPR attributed to the respondent, and the sanction that could be imposed.

Therefore, considering that the respondent has not submitted allegations to the initiation agreement of the file and in accordance with the provisions of Article 64.2.f) of the LPACAP, the aforementioned initiation agreement is considered in this case as a proposal for resolution.

In view of all that has been acted upon, the Spanish Agency for Data Protection considers the following facts proven in this procedure,

PROVEN FACTS

FIRST: On March 26, 2021, B.B.B., A.A.A., and other XXXXX neighbors submitted a document to the Municipality of Riotorto in which they communicated a series of incidents related to the payment for the supply of drinking water service.

SECOND: The Municipality of Riotorto sent a communication to the local neighbors announcing the imminent visit of inspection services to verify the correctness of the installations and, if necessary, rectify the irregularities observed.

THIRD: Along with the communication referred to in the second proven fact, the Municipality of Riotorto sent a copy of the document submitted on March 26, 2021, which included the name and surname of the XXXXX complainants, as well as their handwritten signature. The number of the National Identity Document (DNI) had been anonymized.

FOURTH: The method of communication described in the third proven fact allowed unauthorized

access by third parties to personal data (names and surnames and handwritten signatures) of B.B.B., A.A.A., and the other XXXXX individuals who signed the document of March 26, 2021.

LEGAL GROUNDS

I

Competence

In accordance with the powers granted to each supervisory authority by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in Articles 47 and 48.1 of Organic Law 3/2018, of December 5, on Personal Data Protection and Guarantee of Digital Rights (hereinafter, LOPDGDD), the Director of the Spanish Agency for Data Protection is competent to initiate and resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states: "The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued in its development, and, as long as they do not contradict them, subsidiarily by the general rules on administrative procedures."

II

Security Breach

Article 4.12 of the GDPR establishes that a "personal data breach" is defined as "a breach of security leading to the accidental or unlawful destruction, loss, alteration of, or unauthorized disclosure of, or access to personal data transmitted, stored, or otherwise processed."

In this case, there is a personal data breach under the circumstances indicated above, categorized as a confidentiality breach.

It should be noted that the identification of a security breach does not directly imply the imposition of a sanction by this Agency, as it is necessary to analyze the diligence of the responsible parties and the security measures applied.

III

Infringement of Article 5.1 f) of the GDPR

Article 5.1.f) of the GDPR, Principles relating to processing, states the following:

"1. Personal data shall be:

(...)

f) processed in a manner that ensures appropriate security of the personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage."

5/12

its loss, destruction, or accidental damage, through the application of appropriate technical or organizational measures ("integrity and confidentiality").

In this case, the security breach must be classified as a confidentiality breach due to unauthorized or unlawful access to personal data of the claimants and the other XXXXX signatories of the document submitted on March 26, 2021, by external third parties.

Article 5 of the LOPDGDD, Duty of Confidentiality, states the following:

"1. The data controllers and processors, as well as all persons involved in any phase of this, shall be subject to the duty of confidentiality referred to in Article 5.1.f) of Regulation (EU) 2016/679.

2. The general obligation mentioned in the previous section shall be complementary to the professional secrecy duties in accordance with the applicable regulations.

3. The obligations established in the previous sections shall remain in effect even when the relationship of the obligated party with the controller or processor has ended."

Unauthorized access to personal data of the claimants and the other five signatories of the document submitted on March 26, 2021, by external third parties, violating the principle of confidentiality, constitutes a breach of the provisions of Article 5.1.f) of the GDPR.

IV

Classification and Qualification of the Breach of Article 5.1 f) of the GDPR

The aforementioned breach of Article 5.1 f) of the GDPR constitutes one of the infringements classified in Article 83.5 of the GDPR, which under the heading "General Conditions for the Imposition of Administrative Fines" provides:

"5. Infringements of the following provisions shall be sanctioned, in accordance with paragraph 2, with

administrative fines of up to 20,000,000 EUR or, in the case of an enterprise, an amount equivalent to a maximum of 4% of the total annual global turnover of the previous financial year, opting for the higher amount:

a) the basic principles for processing, including the conditions for consent under Articles 5, 6, 7, and 9;" In this regard, the LOPDGDD, in its Article 71 "Infringements," establishes that "Acts and conduct referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those contrary to this organic law, constitute infringements."

For the purposes of the statute of limitations, Article 72 "Infringements Considered Very Serious" of the LOPDGDD indicates:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

6/12

"1. In accordance with what is established in Article 83.5 of Regulation (EU) 2016/679, infringements that constitute a substantial violation of the articles mentioned therein shall be considered very serious and shall be subject to a three-year statute of limitations, particularly the following:

a) The processing of personal data violating the principles and guarantees established in Article 5 of Regulation (EU) 2016/679."

V

Sanction for the Breach of Article 5.1 f) of the GDPR

Article 83 "General Conditions for the Imposition of Administrative Fines" of the GDPR, paragraph 7, establishes:

"Without prejudice to the corrective powers of the supervisory authorities under Article 58, paragraph 2, each Member State may establish rules on whether and to what extent administrative fines may be imposed on authorities and public bodies established in that Member State."

Furthermore, Article 77 "Applicable Regime for Certain Categories of Controllers or Processors" of the LOPDGDD provides the following:

"1. The regime established in this article shall apply to the processing for which they are responsible or for which they are processors:

c) The General Administration of the State, the Administrations of the autonomous communities, and the entities that comprise the Local Administration (...)

2. When the controllers or processors listed in paragraph 1 commit any of the infringements referred to in Articles 72 to 74 of this organic law, the competent data protection authority shall issue a resolution sanctioning them with a warning. The resolution shall also establish the measures that should be taken to cease the conduct or correct the effects of the infringement that has been committed.

The resolution shall be notified to the controller or processor, to the body to which they are hierarchically subordinate, if applicable, and to the affected parties who had the status of interested parties, if applicable.

(...)

4. The resolutions relating to the measures and actions referred to in the previous paragraphs shall be communicated to the data protection authority.

5. The actions taken and the resolutions issued under this article shall be communicated to the Ombudsman or, where applicable, to the analogous institutions of the autonomous communities. (...)"

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

7/12

An infringement of Article 5.1 f) of the GDPR is understood to have been committed, sanctioned with a warning to the City Council of Riotorto.

VI

Infringement of Article 32 of the GDPR

Article 32 of the GDPR, concerning the security of processing, establishes the following:

“1. Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the varying likelihood and severity of risks to the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, which may include, among others:

- a) the pseudonymization and encryption of personal data;
- b) the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services;
- c) the ability to restore the availability and access to personal data quickly in the event of a physical or technical incident;
- d) a process for regularly verifying, assessing, and evaluating the effectiveness of the technical and organizational measures to ensure the security of processing.

2. In assessing the appropriateness of the level of security, particular consideration shall be given to the risks presented by the processing of data, in particular as a consequence of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data (The underlining is ours).

(...)

4. The controller and the processor shall take measures to ensure that any person acting under the authority of the controller or the processor and having access to personal data may only process such data on instructions from the controller, unless required to do so by Union or Member State law.”

For its part, Recital 74 of the GDPR states the following:

“The responsibility of the controller for any processing of personal data carried out by them or on their behalf must be established. In particular, the controller must be obliged to implement appropriate and effective measures and must be able to demonstrate compliance of the processing activities with this Regulation, including the effectiveness of the measures. Such measures must take into account the nature, scope, context, and purposes of the processing as well as the risk to the rights and freedoms of natural persons.”

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
8/12

In this regard, recital 75 of the GDPR lists a series of factors or situations associated with risks to the rights and freedoms of data subjects: (the underlining is ours)

“The risks to the rights and freedoms of natural persons, of varying severity and probability, may arise from the processing of data that could cause physical, material, or immaterial harm, particularly in cases where the processing may lead to issues of discrimination, identity theft or fraud, financial losses, damage to reputation, loss of confidentiality of data subject to professional secrecy, unauthorized reversal of pseudonymization, or any other significant economic or social detriment; in cases where data subjects are deprived of their rights and freedoms or prevented from exercising control over their personal data; in cases where the personal data processed reveal ethnic or racial origin, political opinions, religion or philosophical beliefs, trade union membership, and the processing of genetic data, data concerning health, or data concerning sexual life, or criminal convictions and related security measures; in cases where personal aspects are evaluated, in particular the analysis or prediction of aspects related to work performance, economic situation, health, personal preferences or interests, reliability or behavior, situation or movements, in order to create or use personal profiles; in cases where personal data of vulnerable individuals, particularly children, are processed; or in cases where the processing involves a large amount of personal data and affects a large number of data subjects.”

As highlighted in legal basis II, the identification of a security breach does not directly imply the

imposition of a sanction by this Agency, as it is necessary to analyze the diligence of the data controllers and processors and the security measures applied.

The examination of the documentation in the file does not allow for the appreciation of diligent behavior on the part of the City Council.

The City Council sent a communication to the residents of the municipality notifying them of the upcoming inspection of the water facilities, attaching a complaint document that included both the name and surname as well as the handwritten signature of XXXXX residents of that locality.

On one hand, the transfer of such personal data, including the complaint document, was not necessary for the City Council to send the communication to the residents.

On the other hand, the LPACAP does not impose the obligation to transfer the complaint with the personal data of the complainant.

Such behavior demonstrates that, at the time of the breach, the City Council lacked security measures commensurate with the estimated potential risks, as well as adequate training of its employees in the area of personal data protection.

Furthermore, the aforementioned conduct is not consistent with the proactive responsibility enshrined in Article 5.2 of the GDPR, which states:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

9/12

“2. The data controller shall be responsible for compliance with the provisions of paragraph 1 and be able to demonstrate it (‘proactive responsibility’).”

It is considered that the known facts constitute an infringement attributable to the City Council of Riotorto for violation of Article 32 of the GDPR.

VII

Classification and qualification of the infringement of Article 32 of the GDPR

The aforementioned infringement of Article 32 of the GDPR constitutes one of the infringements classified in Article 83.4 of the GDPR, which under the heading “General conditions for the imposition of administrative fines” states:

“Infringements of the following provisions shall be subject to administrative fines of up to 10,000,000 EUR or, in the case of an enterprise, an amount equivalent to 2% of the total annual global turnover of the preceding financial year, opting for the higher amount:

a) the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43; (...)”

In this regard, the LOPDGDD, in its Article 71 “Infringements” establishes that “Acts and conduct referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those that are contrary to this organic law, constitute infringements.”

For the purposes of the statute of limitations, Article 73 “Infringements considered serious” of the LOPDGDD indicates:

“According to what is established in Article 83.4 of Regulation (EU) 2016/679, the following shall be considered serious and shall prescribe after two years: infringements that constitute a substantial violation of the articles mentioned therein and, in particular, the following:

(...)

f) The failure to adopt those technical and organizational measures that are appropriate to ensure a level of security appropriate to the risk of processing, in the terms required by Article 32.1 of Regulation (EU) 2016/679. (...)”

VIII

Sanction for the infringement of Article 32 of the GDPR

Article 83 “General conditions for the imposition of administrative fines” of the GDPR paragraph 7 states:

C/ Jorge Juan, 6

www.aepd.es

"Without prejudice to the corrective powers of the supervisory authorities under Article 58, paragraph 2, each Member State may establish rules on whether and to what extent administrative fines may be imposed on authorities and public bodies established in that Member State."

Furthermore, Article 77 "Regime applicable to certain categories of controllers or processors" of the LOPDGDD provides as follows:

"1. The regime established in this article shall apply to the processing for which the following are responsible or processors:

c) The General Administration of the State, the administrations of the autonomous communities, and the entities that make up the Local Administration (...)

2. When the controllers or processors listed in paragraph 1 commit any of the infringements referred to in Articles 72 to 74 of this organic law, the competent data protection authority shall issue a resolution sanctioning them with a warning. The resolution shall also establish the measures that should be adopted to cease the conduct or to correct the effects of the infringement that has been committed. The resolution shall be notified to the controller or processor, to the body to which it hierarchically depends, if applicable, and to the affected parties who had the status of interested parties, if applicable.

(...)

4. The resolutions relating to the measures and actions referred to in the previous paragraphs shall be communicated to the data protection authority.

5. The actions carried out and the resolutions issued under this article shall be communicated to the Ombudsman or, where applicable, to the analogous institutions of the autonomous communities. (...)"

An infringement of Article 32 of the GDPR is understood to have been committed, sanctioned with a warning to the Town Council of Riotorto.

IX

Imposition of measures to be adopted

It is noted that failure to comply with the order to adopt measures imposed by this body in the sanctioning resolution may be considered an administrative infringement in accordance with the provisions of the GDPR, classified as an infringement in its Article 83.5 and 83.6, which could lead to the initiation of further administrative sanctioning proceedings.

Therefore, in accordance with the applicable legislation and having assessed the criteria for the graduation of the sanctions whose existence has been established, the Director of the Spanish Agency for Data Protection RESOLVES:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

11/12

FIRST: TO IMPOSE on the TOWN COUNCIL OF RIOTORTO, with NIF P2705400F,

- For an infringement of Article 5.1 f) of the GDPR, classified under Article 83.5 of the GDPR, a sanction of warning.

- For an infringement of Article 32 of the GDPR, classified under Article 83.4 of the GDPR, a sanction of warning.

SECOND: TO NOTIFY this resolution to the TOWN COUNCIL OF RIOTORTO.

THIRD: TO COMMUNICATE this resolution to the Ombudsman, in accordance with the provisions of Article 77.5 of the LOPDGDD.

FOURTH: TO ORDER the TOWN COUNCIL OF RIOTORTO, with NIF P2705400F, that pursuant to Article 58.2.d) of the GDPR, within three months, prove that it has complied with the following measure:

- Review the procedure of the Town Council of Riotorto regarding the sending of external

communications, including those intended for the residents of the municipality, in order to ensure that they comply with the content of both the GDPR and the LOPDGDD.

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative procedure in accordance with Article 48.6 of the LOPDGDD, and in accordance with the provisions of Article 123 of the LPACAP, the interested parties may, optionally, file a motion for reconsideration before the Director of the Spanish Agency for Data Protection within one month from the day following the notification of this resolution or directly file a contentious-administrative appeal before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of Article 25 and paragraph 5 of the fourth additional provision of Law 29/1998, of July 13, regulating the Contentious-Administrative Jurisdiction, within two months from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law. Finally, it is noted that in accordance with the provisions of Article 90.3 a) of the LPACAP, the firm resolution in the administrative procedure may be provisionally suspended if the interested party expresses their intention to file a contentious-administrative appeal. If this is the case, the interested party must formally communicate this fact by writing to the Spanish Agency for Data Protection, submitting it through the Electronic Registry of the Agency

[<https://sedeagpd.gob.es/sede-electronica-web/>], or through any of the other registries provided for in Article 16.4 of Law 39/2015, of October 1. They must also provide the Agency with documentation proving the effective filing of the contentious-administrative appeal. If the Agency does not become aware of the filing of the contentious-administrative appeal within two months from the day following the notification of this resolution, it will consider the provisional suspension to be concluded.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

12/12

938-010623

Mar España Martí

Director of the Spanish Agency for Data Protection

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es